

INTRODUCTION TO CYBERSECURITY & EMERGING TECHNOLOGY & THREATS TO CYBERSECURITY

INTRODUCTION TO CYBER SECURITY

Cyber Security is the protection of information systems (hardware, software, associated infrastructure), the data and services they provide from unauthorized access, harm, or misuse, including harm caused intentionally by the operator or accidentally due to failure to follow security procedures.

It involves people, processes, and technologies working together to provide threat reduction, vulnerability reduction, deterrence, incident response, resiliency, recovery, computer network operations, information assurance, and law enforcement.

Cyber Security also refers to the techniques and practices designed to protect digital data that is stored, transmitted, or used on an information system.

- ✿ **Cyber** – technology, including systems, networks, programs, and data.
- ✿ **Security** – protection, including system security, network security, application security, and information security.

Importance of Cybersecurity

- ✿ Increasing number of users, devices, and programs.
- ✿ Growing volume of sensitive or confidential data.
- ✿ Increasing volume and sophistication of cyber attackers and attack techniques.

Companies need Cyber Security to protect: data, finances & intellectual property

Individuals need Cyber Security to protect: personal data, funds, & important files

- ✿ Public services and government organizations use Cyber Security to ensure

communities can continue relying on their services.

- ✿ As digitization, cloud-based technologies, and mobile technologies continue to grow, Cyber Security has become a requirement for everyone connected with any type of data, not just IT or security administrators.

The history of data breaches

Hacking dates back to 1834, with the first known hackers caught in 1836.

France's Mechanical Telegraph System (Late 1700s)

- ✿ France used a mechanical telegraph system to transfer encrypted data between Paris and Bordeaux. Although encrypted, the system was still vulnerable to attacks.

1980s – Morris Worm

- ✿ The Morris Worm, created by **Robert Tappan Morris**, was the first major computer worm.
- ✿ It spread rapidly through ARPANET, exploiting flaws in Unix sendmail and the fingerd daemon, infecting about 10% of Internet-connected machines.
- ✿ Morris was later convicted under the Computer Fraud and Abuse Act (1990).

2010 – Stuxnet

- ✿ Stuxnet targeted Siemens Industrial Control Systems (ICS) in Iranian nuclear facilities.
- ✿ It became the first major example of industrial cyber espionage.

Modern Cyber Attacks

- ✿ Malware such as Duqu and Flame followed Stuxnet.
- ✿ Common attacks include ransomware, data theft/destruction, and cryptocurrency

Scenarios for security

Scenario (organizations in general):

Organizations must keep their digital and IT

infrastructure secure and operational. They are responsible for protecting identity, data, networks, equipment, products, business processes, and applications. While digitization improves connectivity and business operations, it also increases security risks. Organizations must secure identities by controlling access, protect data at rest, in motion, and during processing, and secure the network perimeter (physical or cloud) with proper controls.

Scenario (everything is moving to cloud):

Organizations adopt cloud computing because it provides higher processing capability, scalability, lower operating costs, better collaboration, remote work support, and reduced hardware and software maintenance. However, cloud computing also introduces security concerns, including data access and privacy, regulatory compliance (e.g., GDPR), disaster recovery (DR) dependence on the cloud provider, and data sovereignty.

The importance of securing the network and applications

As the number of connected devices continues to grow, the risk of cyber attacks also increases. Regardless of the size of a business, no network or application is completely safe from attacks. Therefore, it is essential to maintain sustainable, dependable, and efficient networks and applications. Properly configured systems and applications help reduce the risk of attacks but cannot eliminate it completely.

Modern IT security uses a layered security approach, as a single layer is no longer sufficient. A network breach can result in financial loss, operational disruption, and loss of trust. Common attack vectors include *viruses, Trojans, custom malware, zero-day attacks*, and *insider threats*.

Understanding the attack surface

❖ An **attack surface** is the collection of potential vulnerabilities (attack vectors) that can allow unauthorized access to a system, data, or network.

❖ **Attack vectors** include software, hardware, networks, and users (human factor). A larger attack surface increases the risk of compromise, while reducing attack vectors lowers the risk.

Applications, network infrastructure, and individuals are common cyber attack targets. Web-facing applications are especially vulnerable and can compromise the entire network and its data. Poor access controls can also lead to insider threats.

❖ **Network attacks** can be passive or active.

❖ **Passive attacks** capture passwords or sensitive information by monitoring network traffic.

❖ **Active attacks** use malware or network vulnerabilities to bypass security, expose data, or launch Denial-of-Service (DoS) attacks.

Common attack vectors include *social engineering, scams, drive-by downloads, malicious URLs and scripts, browser-based attacks, supply chain attacks*, and *network-based attacks*.

The threat landscape

A threat landscape is the collection of observed threats, information about threat agents, and current threat trends. It is important for security professionals to keep track of the threat landscape to understand emerging cyber security risks.

Threat landscape reports are published by agencies and security organizations such as ENISA (European Union Agency for Cybersecurity) and NIST (National Institute of Standards and Technology). The ENISA Threat Landscape (ETL) is an annual report that provides an overview of the current state of the cybersecurity threat landscape.

CYBER SECURITY FUNDAMENTALS

Authentication, authorization, and non-repudiation are tools that system

designers can use to maintain system security with respect to confidentiality, integrity, and availability.

The **CIA Triad** consists of the three core principles of information security that professionals protect in every system. To properly enforce these principles, security professionals must understand authentication, authorization, and non-repudiation.

The CIA Triad is an information security model, which is widely popular. It guides an organization's efforts towards ensuring data security. It forms the cornerstone of a security infrastructure.

- 🔗 **Confidentiality** - makes sure that only authorized personnel are given access or permission to modify data

- 🔗 **Integrity** - helps maintain the trustworthiness of data by having it in the correct state and immune to any improper modifications

- 🔗 **Availability** - authorized users should be able to access data whenever required

Who created the CIA triad, and when?

The CIA Triad is a foundational concept in information security that has guided security professionals for more than two decades.

- 🔗 It did not have a single creator but emerged over time as an accepted principle among information security professionals.

- 🔗 **Confidentiality** – formalized in a 1976 U.S. Air Force study.

- 🔗 **Integrity** – emphasized in a 1987 paper on maintaining correct commercial data

- 🔗 **Availability** – gained importance after the 1988 Morris Worm disrupted a large portion of the Internet.

- 🔗 By 1998, the CIA Triad was widely recognized as a foundational concept.

Donn Parker later proposed expanding it into the Parkerian Hexad (six-element framework).

- 🔗 Because it is a widely accepted concept rather than the work of a single person, many security professionals have

developed their own interpretations and extensions.

Importance of the CIA Triad

The CIA Triad provides a framework for selecting appropriate security techniques, software, and services to address security concerns. The three principles work together but may conflict with one another (e.g., stronger confidentiality through strict authentication may reduce availability). Helps organizations develop effective security policies by balancing the CIA.

Confidentiality - Common threats include privilege escalation, eavesdropping, man-in-the-middle attacks, and weak passwords.

- 🔗 **Countermeasures:** access controls, strong authentication, data encryption, data classification, and cybersecurity awareness/training.

Integrity - It supports non-repudiation.

- 🔗 **Countermeasures:** hashing, digital signatures, encryption, digital certificates, intrusion detection systems (IDS), auditing, and access controls.

Availability - Common threats include hardware/software failures, natural disasters, human error, and DDoS attacks.

- 🔗 **Countermeasures:** redundancy, fault tolerance, backups, disaster recovery plans, software patching, and DoS protection.

Implementation of the CIA Triad

Organizations should implement the CIA Triad based on their security needs, nature of the business, industry, and regulatory requirements as prioritizing one principle may affect the others.

Pros of the CIA Triad

- 🔗 **Simple:** Provides clear and easy-to-understand security principles, reducing human error.

- 🔗 **Balanced:** Considers both security and availability to support business needs.

- 🔗 **Open-ended:** Can adapt as organizations grow and upgrade their technology.

Cons of the CIA Triad

- 🔗 **Limited:** Mainly focuses on data protection and may not address threats like social engineering and phishing.
- 🔗 **Lacks specificity:** Does not provide detailed guidance for building a complete security model.
- 🔗 **Not holistic:** Should be combined with other security frameworks for stronger protection.

How can the CIA be achieved?

Classify information first to determine the level of protection required.

- 🔗 **Confidentiality:** Use encryption so only authorized users can read the information.
- 🔗 **Integrity:** Use hashing to verify that data has not been modified.
- 🔗 **Availability:** Use redundancy (e.g., backup servers and RAID) to keep systems and data accessible during failures.

SECURITY VULNERABILITIES, THREATS & ATTACKS

Cybersecurity risks are constantly evolving as cyber criminals develop new hacking techniques and launch attacks quickly. Staying secure requires understanding the current threats targeting an organization.

Businesses face cyber attacks every day, making threat awareness and timely security measures essential. As former Cisco CEO John Chambers said, *"There are two types of companies: those that have been hacked, and those who don't yet know they have been hacked."* This highlights that every organization is a potential target.

Vulnerability, threat, Harmful acts

No system is completely immune to attacks. Organizations that manage, transmit, or store data must implement security measures to monitor their cyber environment, identify vulnerabilities, and fix security weaknesses.

Cyber threats are security incidents or circumstances with the potential to have a

negative outcome for your network or other data management systems.

Threats have the potential to steal or damage data, disrupt business, or create harm in general. To keep that from happening, you need to know what cyber threats exist. *In general terms, there are three categories.*

- ❑ **Intentional threats:** malware, ransomware, phishing, malicious code, and wrongfully accessing user login credentials. They are activities or methods bad actors use to compromise a security or software system.
- ❑ **Unintentional threats:** often attributed to human error.
- ❑ **Natural threats:** unpredictable and have the potential to damage your assets.

Threat probability is multiplied by the potential loss that may result, cyber security experts, refer to this as a **risk**.

Vulnerabilities are the gaps or weaknesses in a system that make threats possible and tempt threat actors to exploit them. Some common examples are:

- ❑ **Broken Authentication:** When authentication credentials are compromised, user sessions and identities can be hijacked by malicious actors to pose as the original user.
- ❑ **SQL Injection:** As one of the most prevalent security vulnerabilities, attackers inject malicious code to access databases. Successful attacks can result in data theft, identity spoofing, and other harmful activities.

- ❑ **Cross-Site Scripting (XSS):** An attack that injects malicious code into websites to target users instead of the website itself, potentially exposing sensitive user information.

- ❑ **Cross-Site Request Forgery:** CSRF attack aims to trick an authenticated user into performing an action that they do not intend to do. This, paired with social

engineering, can deceive users into accidentally providing a malicious actor with personal data.

□ **Security Misconfiguration:** Any component of a security system that can be leveraged by attackers due to a configuration error can be considered a “Security Misconfiguration.”

Vulnerabilities can lead to data leaks and data breaches. A **data leak** occurs when data is accidentally exposed due to mistakes, while a **data breach** occurs when data is intentionally stolen by attackers.

Risk - potential for loss, damage or destruction of assets or data caused by a cyber threat. **Threat** - process that magnifies the likelihood of a negative event, such as the exploit of a vulnerability.

Cyber Attack Objectives

- Gaining, or attempting to gain, unauthorized access to a computer system or its data.
- Unwanted disruption or denial of service attacks, including the take down of entire web sites
- Installation of viruses or malware - that is malicious code on a computer system
- Unauthorized use of a computer system for processing or storing data.
- Changes to the characteristics of a computer system's hardware, firmware or software without the owner's knowledge, instruction or consent, and
- Inappropriate use of computer systems by employees or former employees.

Types of Cyber Attack

The **InfoSec industry** continues to grow as organizations face increasing cyber threats. While security software improves in detecting and preventing attacks, lack of cybersecurity awareness and education remains a major risk.

Cyber-attacks can be classified into the following categories:

1. Web-based attacks
2. System-based attack

The Most Common Types Of Cyber Attacks

A Denial-Of-Service (DOS) and Distributed Denial-of-Service Attack -

DoS attack floods a network or server with requests until legitimate users can no longer access it. A **DDoS** attack uses multiple compromised devices to launch the attack.

□ **Example:** Thousands of fake requests consume the available bandwidth, preventing real users from reaching the server.

□ **How effective?** DDoS attacks can generate massive amounts of traffic, overwhelming even well-prepared organizations.

□ **Impact:** Causes service disruption, downtime, and delays while malicious traffic is identified and blocked.

Malware - malicious software that includes viruses, worms, spyware, and ransomware. It commonly enters through phishing emails, infected attachments, or USB devices.

□ **Example:** Ransomware encrypts files and demands payment to restore access.

□ **How effective?** Malware, especially ransomware, is one of the most common and damaging cyber attacks because it spreads easily and can affect millions of users.

□ **Impact:** Can block systems, steal information, damage files, and paying the ransom does not guarantee data recovery.

Man-in-the-middle (MITM) Attacks - a

MITM attack occurs when an attacker secretly intercepts communication between two parties to monitor, steal, or modify data.

Two common points of entry for MitM attacks:

1. Malware is inserted into a device directly. The traffic is then monitored and harvested. More sophisticated versions can lay dormant for months, until a very valuable piece of data appears.
2. On unsecure public Wi-Fi, attackers can insert themselves between your device and the network. Without knowing, you pass all information

through the attacker, rather than the coffee shop Wi-Fi.

- **Example:** Using unsecured public Wi-Fi, an attacker can intercept information sent between your device and the network.

- **How effective?** MITM attacks are difficult to detect because they often occur without the victim noticing.

- **Impact:** Used to steal sensitive information and support phishing attacks or corporate espionage.

Phishing - uses fake emails, websites, or messages from trusted sources to trick users into revealing information or clicking malicious links.

- **Example:** An email pretending to be from your bank or employer asks you to log in or provide personal information.

- **How effective?** Phishing is one of the most common cyber attacks because it exploits human psychology, and even experienced users can be deceived.

- **Impact:** Can lead to stolen credentials, identity theft, financial loss, and malware infection. A phishing attack targeting executives is called Whaling.

SQL injection - injects malicious SQL code into website input fields to access or manipulate a database.

- **Example:** A poorly secured website may reveal customer names, passwords, and banking information.

- **How effective?** SQL injection is less common today because of secure coding practices, SSL, and input validation, but it remains dangerous for vulnerable websites.

- **Impact:** Can cause data theft, financial loss, and reputational damage.

Other Types of Cyber Attacks

- **DNS Spoofing** - type of computer security hacking that inserts false information into a DNS cache, causing users to be redirected to a fake or attacker-controlled IP address. It can remain undetected for a long time and cause serious security issues.

- **Session Hijacking** - a security attack on a user session over a protected network. Web applications create cookies to store the state and user sessions. By stealing the cookies, an attacker can have access to all of the user data

- **Brute force** - a type of attack which uses trial and error to guess passwords, PINs, or encrypted data by generating many possible combinations. It can be used by attackers to gain unauthorized access or by security professionals to test network security.

- **Dictionary attacks** - this type of attack stored the list of a commonly used password and validated them to get original password

- **URL Interpretation** - it is a type of attack where we can change certain parts of a URL, and one can make a web server to deliver web pages for which he is not authorized to browse.

- **File Inclusion attacks** - it is a type of attack that allows an attacker to access unauthorized or essential files which are available on the web server or to execute malicious files on the web server by making use of the include functionality.

Malware

A software designed to gain unauthorized access to or be installed on a computer without the user's consent. It performs unwanted tasks that benefit a third party, ranging from disrupting system performance to stealing sensitive data and sending it to remote servers.

Types of Malware

- **Adware** - displays forced advertisements by redirecting users to advertising websites or showing pop-up ads. It is usually funded by the companies being advertised.

- **Spyware** - secretly installs on a computer to collect sensitive information, such as browsing activity, cookies, and keystrokes (keylogging), and sends the data to a

remote server. It is often bundled with freeware.

- **Browser Hijacker** - Browser hijacking software changes browser settings without the user's knowledge and redirects users to unwanted websites. It is commonly installed with free software.

- **Virus** - a malicious code that damages files, slows system performance, consumes memory, or formats the computer. It spreads through email attachments, USB drives, images, audio/video files, and requires human action (e.g., opening an executable file) to activate.

- **Worm** - a self-replicating malware that spreads automatically through networks, operating system vulnerabilities, or email without human intervention. It consumes network bandwidth and resources, slowing or disrupting the network.

- **Trojan Horse** - it disguises itself as legitimate software to trick users into installing it. It can damage data, create a backdoor for remote access, and turn the infected computer into a zombie in a botnet. Unlike viruses and worms, it does not replicate.

- **Scareware** - displays fake security warnings that claim the computer is infected and tricks users into downloading or paying for fake security software. The malware may lock the system or demand a ransom before access is restored.

Motive of Attackers

Operational cybersecurity risks arise from *three types of actions*:

- **Inadvertent actions** – unintentional mistakes, usually by insiders.

- **Deliberate actions** – intentional actions by insiders or outsiders to cause harm.

- **Inaction** – generally by insiders, failure to act due to lack of skills, knowledge, guidance, or availability.

The primary concern in cybersecurity is deliberate actions, which are driven by different attacker motivations.

- **Political motivations**: destroying, disrupting, or taking control of targets; espionage; and making political statements, protests, or retaliatory actions.

- **Economic motivations**: theft of intellectual property or other economically valuable assets, fraud, industrial espionage and sabotage, and blackmail.

- **Socio-cultural motivations**: attacks with philosophical, theological, political, and even humanitarian goals. Include fun, curiosity, and a desire for publicity or ego gratification.

Categories of Attacks: Active & Passive

Active attacks: is a network exploit in which a hacker attempts to make changes to data on the target or data en route to the target

Types of Active attacks:

- **Masquerade**: the intruder pretends to be a particular user of a system to gain access or to gain greater privileges than they are authorized for. A masquerade may be attempted through the use of stolen login IDs and passwords, through finding security gaps in programs or through bypassing the authentication mechanism.

- **Session replay**: a hacker steals an authorized user's log in information by stealing the session ID. The intruder gains access and the ability to do anything the authorized user can do on the website.

- **Message modification**: an intruder alters packet header addresses to direct a message to a different destination or modify the data on a target machine.

- **(DoS) attack** - users are deprived of access to a network or web resource. Overwhelming the target with more traffic than it can handle.

- **DDoS** - exploit, large numbers of compromised systems (sometimes called a

botnet or zombie army) attack a single target

Passive Attacks: relatively scarce from a classification perspective, but can be carried out with relative ease, particularly if the traffic is not encrypted

Types of Passive attacks:

- **Eavesdropping (tapping):** the attacker listens to communications between two parties. It is most effective when the traffic is unencrypted, allowing attackers to obtain sensitive information such as passwords.

- **Traffic analysis:** examines network metadata (e.g., traffic rate and duration) to gather information about communications. Even if the data is encrypted, traffic analysis can support cryptanalysis, potentially helping attackers uncover or decrypt information.

- **Software Attacks:** Malicious code is a type of software designed to take over or damage a computer user's operating system.

Hardware Attacks:

Common hardware attacks include:

- Manufacturing backdoors, for malware or other penetrative purposes; backdoors aren't limited to software and hardware, but they also affect embedded radio-frequency identification (RFID) chips and memory

- Eavesdropping by gaining access to protected memory without opening other hardware

- **Fault induction** – intentionally causing hardware malfunctions or abnormal behavior.

- **Hardware modification (tampering)** – physically altering hardware to compromise security.

- **Backdoor creation** – adding hidden methods to bypass authentication.

- Counterfeiting product assets that can produce extraordinary operations and those made to gain malicious access to systems.

7 LAYERS OF CYBERSECURITY

Many cybersecurity solutions work separately, creating a siloed approach where systems do not share information, making malware threats harder to detect and stop. The increasing number of connected devices and lack of security integration have created more complex cyber risks.

Traditional security tools like firewalls and antivirus software are no longer enough. Modern cybersecurity uses a layered approach, combining multiple security techniques to protect endpoints (devices), environments (systems and networks), and users from cyber threats.

The first step is to assess the organization's security status using penetration testing, vulnerability assessments, and risk analysis. These help identify weaknesses, understand possible threats, and create defenses against unknown attacks, ransomware, and malware.

There are seven integrated components that should make up your organization's layered cybersecurity approach:

1. Human Layer - the most vulnerable part of cybersecurity because many attacks result from human error. Organizations should provide security awareness training on phishing, password security, cyber scams, and safe practices. Proper access control also helps limit damage during a breach.

◇ **Example:** User training and awareness help employees identify and report phishing emails. Other protections include multi-factor authentication (MFA), security policies, patch management, and proper firewall configuration.

2. Perimeter Layer - protects the outer boundary of a network, including connected

devices such as computers, mobile devices, printers, and IoT devices. Organizations must identify connected devices, protect them, and secure data passing through them.

◇ **Example:** Firewalls, spam filters, and intrusion detection/prevention systems (IDS/IPS) act as the first barrier against attackers by blocking unauthorized access.

3. Network Layer - focuses on controlling activities after an attacker enters the system. Security is improved by providing users with only the access needed for their job, limiting possible damage.

◇ **Example:** Secure network design, VLANs, and multi-layer firewalls/switches help separate systems and prevent attackers from moving freely within the network.

4. Endpoint Layer - protects devices connected to the network, such as computers, servers, and mobile devices. Since many devices can connect to a network, each endpoint needs strong protection.

◇ **Example:** Antivirus, software firewalls, breach detection agents, encryption, and Mobile Device Management (MDM) help secure and manage devices.

5. Application Layer - protects software and applications used by organizations. Applications must be updated and secured to prevent vulnerabilities.

◇ **Example:** Patching and software updates fix security weaknesses. Sandboxing helps prevent unauthorized access through browser-based applications.

6. Data Layer - protects valuable information such as customer data, payment information, and intellectual property. Data security is essential because data loss can damage trust and business operations.

◇ **Example:** Encryption (at rest and in motion), backups, authentication systems, and data management policies protect data confidentiality and integrity.

7. Mission Critical Assets - the resources an organization cannot operate without, such as software, hardware, systems, and important records. Organizations must identify and protect these assets.

◇ **Example:** Backups, incident response, and recovery plans help maintain operations during security incidents.

